**ФГБОУ ВО «Московский технологический университет»**
**Институт кибербезопасности и цифровых технологий**

**Кафедра КБ-1 «Защита информации»**

**Дисциплина: «Разработка и эксплуатация автоматизированных систем в защищенном исполнении»**

**Отчет по лабораторной работе №1**

# Тема: “Нотация BPMN в построении статической модели области функционирования АСЗИ «как есть» (точка зрения инженера по ЗИ АС)”

**Вариант задания №10**

**Выполнил**:
Студент группы БАСО-04-22
Кузнецов Алексей Александрович

**Проверил**:
доцент Федин Ф.О.

**Москва, 2026**

**Учебная цель занятия**: Углубить теоретические знания и выработать практические умения применения инструментального средства Bizagi Modeler для построения модели предметной области «как есть».

**Место проведения занятия**: компьютерная аудитория.

**Учебно-материальное обеспечение**:

1) Методическая разработка.

2) Компьютерный класс с ПЭВМ.

3) Bizagi Modeler.

**Задание №1**. Самостоятельно повторить все действия по построению статической модели защиты процесса продажи товаров в торговой компании «Гамма». Моделирование выполнить в инструментальном средстве Bizagi Modeler (нотация BPMN 2.0). Модель должна быть построена с точки зрения сотрудника службы ИБ.

**Ход выполнения задания**

В рамках изучения методов защиты информации в автоматизированных системах была разработана статическая модель, отражающая ключевые аспекты обеспечения безопасности в процессе продажи товаров в торговой компании «Гамма». Модель построена с точки зрения сотрудника службы информационной безопасности и позволяет визуализировать потенциальные риски и меры защиты на каждом этапе бизнес-процесса. Детальное описание статической модели защиты информации в процессе продажи товаров торговой компании «Гамма» представлены на рисунке 1.

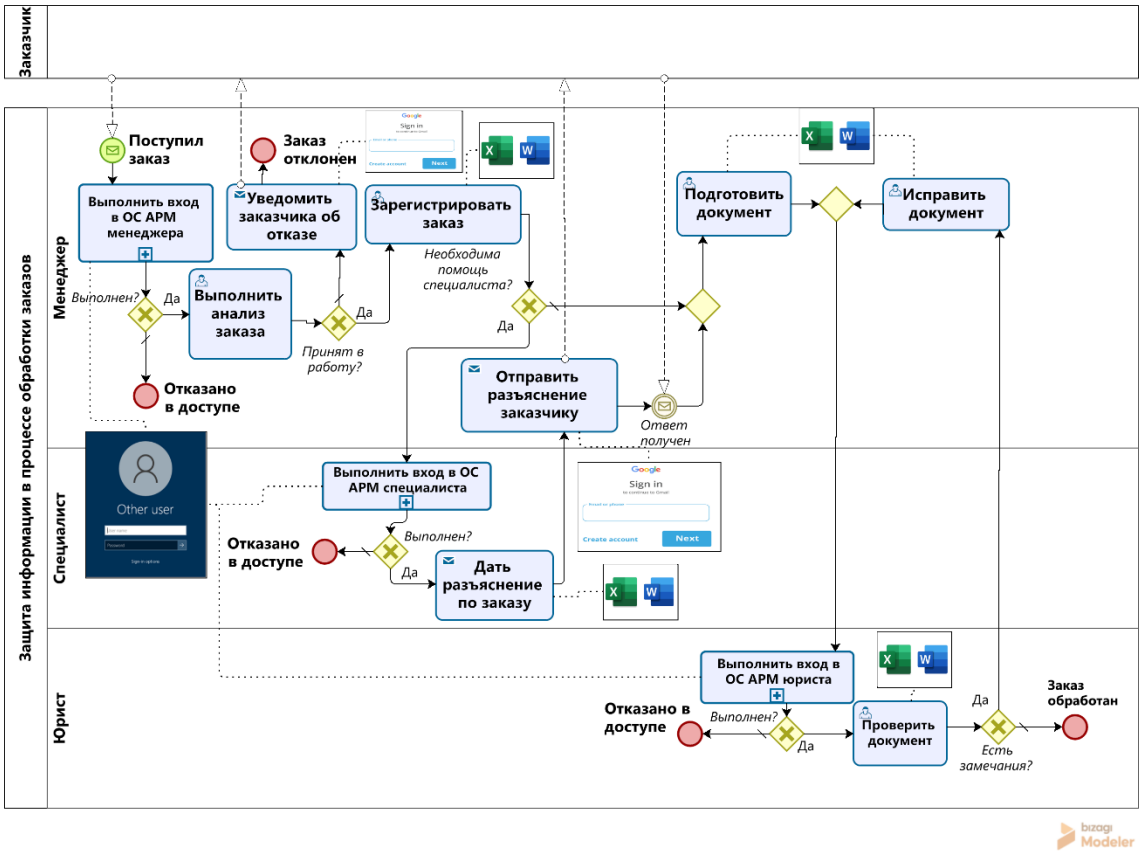



Рисунок 1 – Модель ЗИ в процессе продажи товаров

Представленная модель описывает процесс обработки заказа в компании «Гамма» с точки зрения информационной безопасности. Процесс начинается с получения заказа от заказчика по внешней электронной почте, после чего менеджер анализирует заказ. Если заказ принят к исполнению, он регистрируется, и при необходимости привлекается специалист для консультации. Подготовленный документ отправляется на проверку юристу, который при наличии замечаний возвращает его на доработку менеджеру. В модели “как есть” отсутствует служба информационной безопасности и неудачные попытки входа в систему никак не журналируются, двухфакторная аутентификация не внедрена в текущие процессы, парольная политика слабая и давно не обновлялась. Весь документооборот проходит на рабочих станциях сотрудников с использованием офисных пакетов. Взаимодействие с клиентами и между сотрудниками происходит по внешней электронной почте.

**Задание №2**. Для предметной области своего варианта, в инструментальном средстве Bizagi Modeler (нотация BPMN 2.0), построить статическую модель защиты выбранного процесса автоматизации (модель «as-is»). Если автоматизируемых процессов несколько, то для моделирования выбрать наиболее значимый из них. Модель должна быть построена с точки зрения сотрудника службы ИБ.

**Ход выполнения задания**

Предметной областью является процесс учета кадров маркетинговой компании. Рассматривается этап трудоустройства уже утвержденного кандидата, начиная с момента принятия положительного решения руководством. Особенностью текущего состояния процесса («as-is») является полное отсутствие специализированных автоматизированных систем. Все операции выполняются вручную с использованием стандартного пакета офисных приложений (MS Word, MS Excel), бумажных носителей и публичных почтовых сервисов (например, Gmail) для внешней и внутренней коммуникации.

**Краткие сведения об объектах автоматизации**

ООО "Маркетинг с умом" предоставляет услуги в области маркетинга, включая развитие брендов заказчиков и улучшение их узнаваемости на рынке. Организационная структура является функциональной и возглавляется группой директоров, каждый из которых курирует определенный блок деятельности.

Количество сотрудников: 100-150 человек. В настоящее время используются офисные пакеты операционной системы Windows и бумажные журналы для учета кадров. Автоматизированная система отсутствует.

**Организационная структура управления**

В подчинении исполнительного директора находятся отделы кадров, бухгалтерия, административно-хозяйственное управление. Креативный директор управляет креативной группой, директор по стратегии и аналитике отвечает за маркетинговые исследования, директор по клиентскому сервису управляет взаимодействием с клиентами, технический директор отвечает за технологическое развитие, директор по ИТ-поддержке обеспечивает работу IT-инфраструктуры.

Задачи, стоящие перед отделом кадров:

1. Подбор, расстановка и воспитание кадров.

2. Изучение деловых и моральных качеств работников по их практической деятельности.

3. Создание резерва кадров для выдвижения на руководящие и материально ответственные должности.

4. Организация и проведение всех видов подготовки и повышения квалификации кадров.

5. Учет кадров.

6. Обеспечение прав, льгот и гарантий работников предприятия.

**Начальник отдела кадров** несет ответственность за разработку и реализацию кадровой политики и стратегии предприятия. В его обязанности входит стратегическое планирование потребности в кадрах, организация работы по подбору и воспитанию управленческого резерва, контроль за выполнением решений аттестационных комиссий, а также анализ текучести кадров и разработка мероприятий по ее снижению. Он координирует всю деятельность отдела и взаимодействует с топ-менеджментом компании.

**Менеджер по подбору и адаптации персонала** реализует функцию комплектования предприятия кадрами. Он изучает рынок труда, устанавливает связи с учебными заведениями и службами занятости, организует публикацию вакансий и проводит отбор кандидатов совместно с

руководителями подразделений. Кроме того, он отвечает за информирование сотрудников о внутренних вакансиях, организацию программ адаптации новичков и формирование банка данных о внешних и внутренних кадрах.

Зона ответственности **специалиста по развитию и обучению персонала** - организация всех видов подготовки и повышения квалификации, основанной на изучении деловых и моральных качеств работников. Он готовит материалы для аттестации, участвует в анализе ее результатов и контролирует выполнение решений комиссий. Также в его функции входит работа с кадровым резервом, разработка программ обучения и развитие карьерных траекторий сотрудников.

Операционную и юридически значимую работу обеспечивает **специалист по кадровому делопроизводству и учету**. Этот сотрудник ведет весь документооборот: оформляет прием, переводы, увольнения, командировки и отпуска в строгом соответствии с ТК РФ. Он ведет табельный учет, личные дела, трудовые книжки, осуществляет воинский учет и готовит отчетность для государственных органов. Именно этот специалист выдает справки о трудовой деятельности, размере заработной платы и готовит документы для пенсионного фонда.

Для обеспечения социальных гарантий и работы с правовыми аспектами в структуре отдела предусмотрена роль **специалиста по социальным гарантиям**. Данный сотрудник обеспечивает соблюдение прав, льгот и гарантий работников. Он рассматривает жалобы и заявления сотрудников по вопросам приема, увольнения и нарушения трудового законодательства, работая над устранением их причин. В его зону ответственности входит контроль за состоянием трудовой дисциплины, соблюдением правил внутреннего распорядка, а также организация работы по предоставлению установленных льгот и компенсаций, включая трудоустройство и переобучение высвобождающихся работников.

Организационная структура управления компании и отдела кадров представлена на рисунках 2 и 3 соответственно.

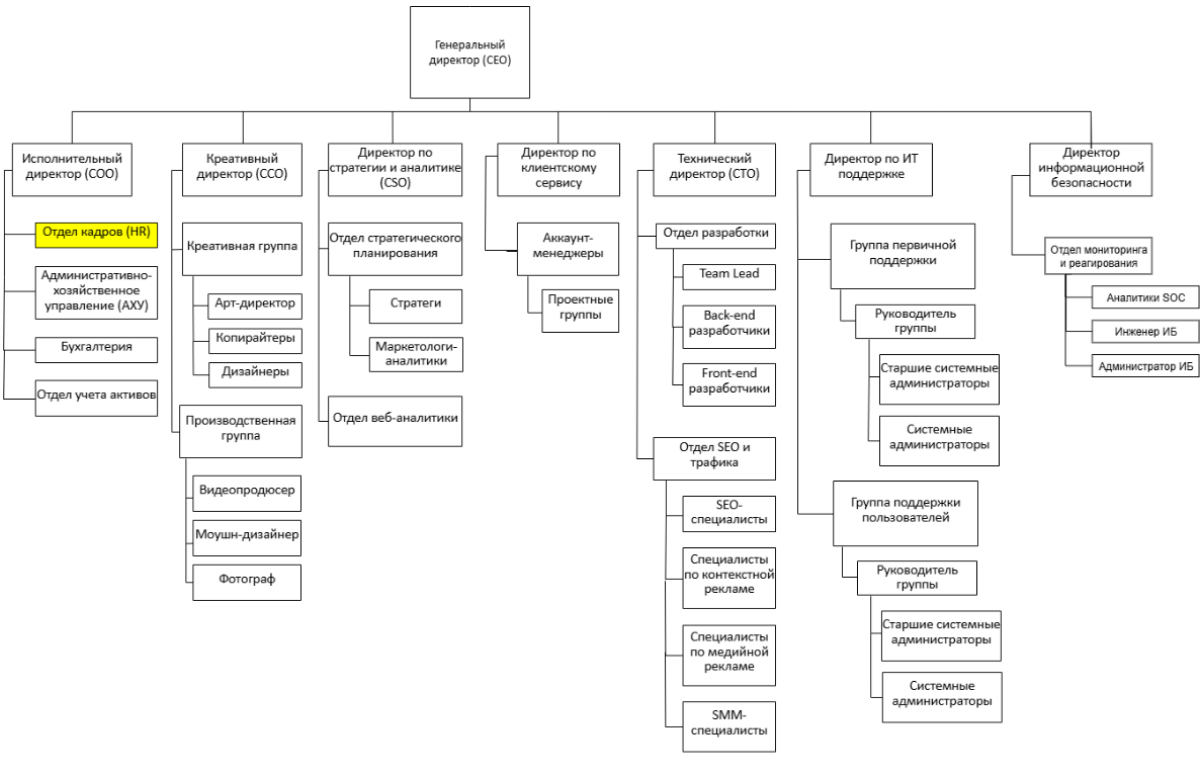



Рисунок 2 – Организационная структура управления в компании «Маркетинг с умом»




Рисунок 3 – Организационная структура управления в отделе кадров

**Схема информационного обмена**

Обработка персональных данных (ПДн) осуществляется в соответствии с Федеральным законом от 27.07.2006 №152-ФЗ «О персональных данных».

Информационные потоки включают: данные кандидатов и сотрудников (ФИО, паспортные данные, контактные данные, ИНН, СНИЛС, банковские реквизиты), трудовые договоры, приказы, личные карточки, сведения коммерческой тайны (планы организационных изменений, результаты аттестаций, кадровый резерв).

Защита ПДн должна осуществляться в соответствии с требованиями Федерального закона от 27.07.2006 №152-ФЗ «О персональных данных», а

также согласно приказу ФСТЭК России от 18.02.2013 №21, который утверждает состав и содержание организационных и технических мер по обеспечению безопасности ПДн.

Обработка сведений, составляющих коммерческую тайну (КТ), осуществляется в соответствии с Федеральным законом от 29.07.2004 №98-ФЗ «О коммерческой тайне». Некоторые сведения КТ, циркулирующие в отделе: Планы организационных изменений, сокращений, масштабного найма до их публичного объявления; результаты внутренних оценок и аттестаций; сведения о кадровом резерве. Защита сведений КТ должна осуществляться в соответствии с требованиями Федерального закона от 29.07.2004 №98-ФЗ «О коммерческой тайне».

Схема информационного обмена в отделе кадров указана на рисунке 4.

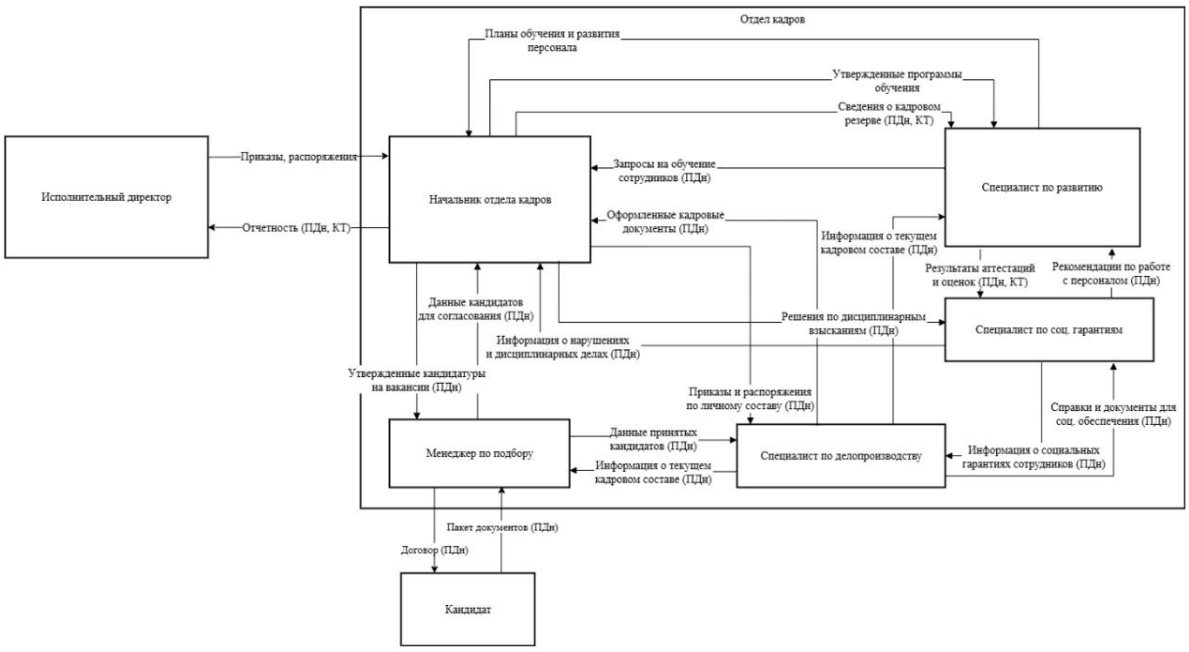



Рисунок 4 – Схема информационного обмена

**Построение статической модели функционирования “как есть”**

На рисунке 5 представлена статическая модель защиты информации в процессе трудоустройства утвержденного кандидата. Основной пул “Процесс трудоустройства утвержденного кандидата” разделен на несколько дорожек, которые соответствуют ролям участников: “Менеджер по подбору

кандидатов”, “Специалист по (кадровому) делопроизводству”.

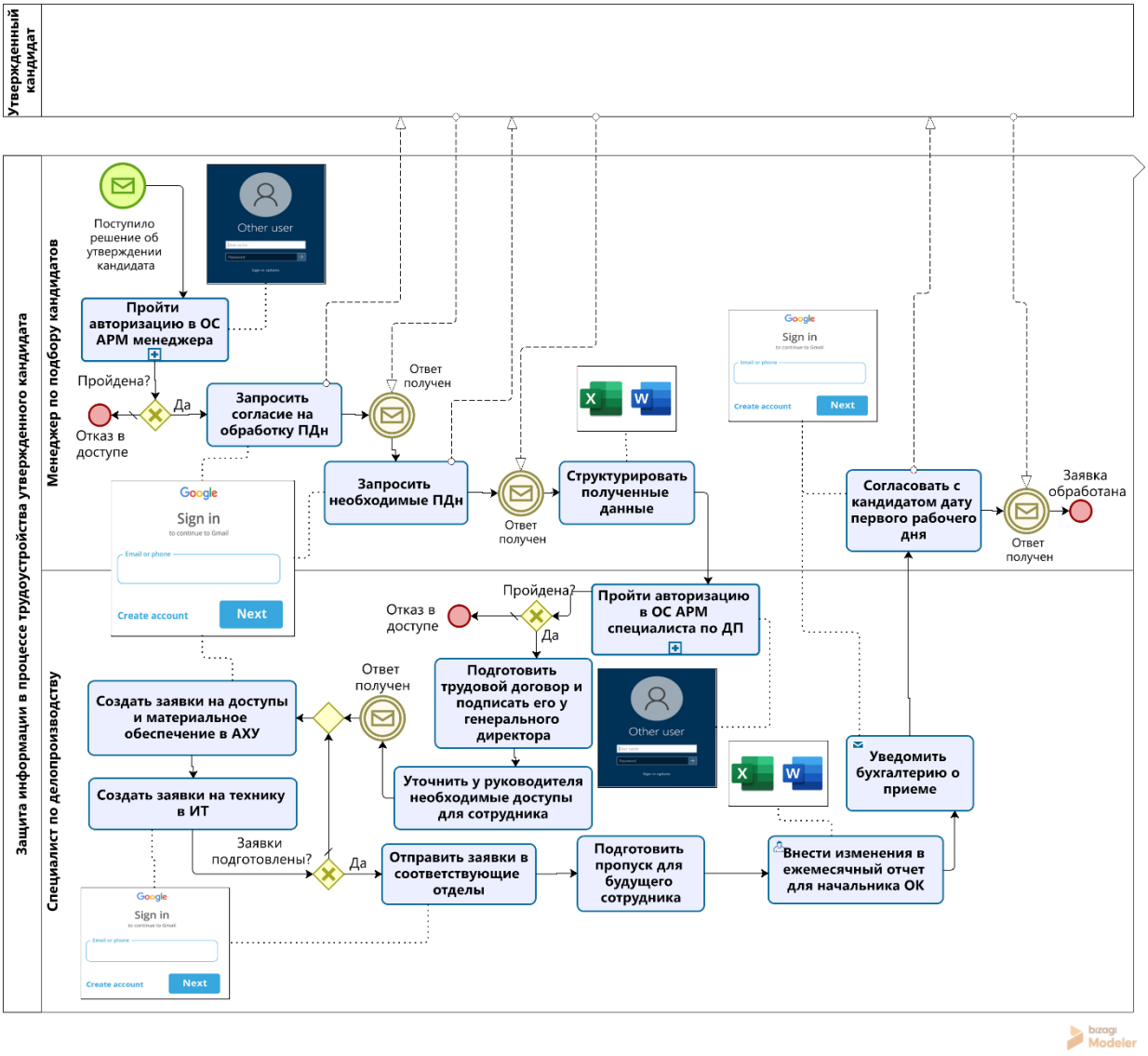



Рисунок 5 – Модель защиты информации в процессе трудоустройства утвержденного кандидата

Процесс начинается с неформальной инициации со стороны руководителя одного из отделов, который устно или через мессенджер сообщает менеджеру по подбору кандидатов о необходимости оформления нового сотрудника.

Далее менеджер по подбору кандидатов проходит процедуру однофакторной парольной аутентификации для входа в операционную систему своего автоматизированного рабочего места (рисунок 6).

Пользователь, который правильно введет логин и пароль, получает беспрепятственный доступ к имеющимся данным, включая персональные данные кандидатов. Такой способ однофакторной парольной аутентификации имеет ряд недостатков:

– пользователи, благодаря собственной беспечности, могут применять пароли, которые можно легко угадать или подобрать (отсутствует парольная политика);

– логин и пароль могут быть перехвачены или подсмотрены в процессе его ввода;

– логин и пароль можно получить от владельца путем его подкупа или шантажа и др.

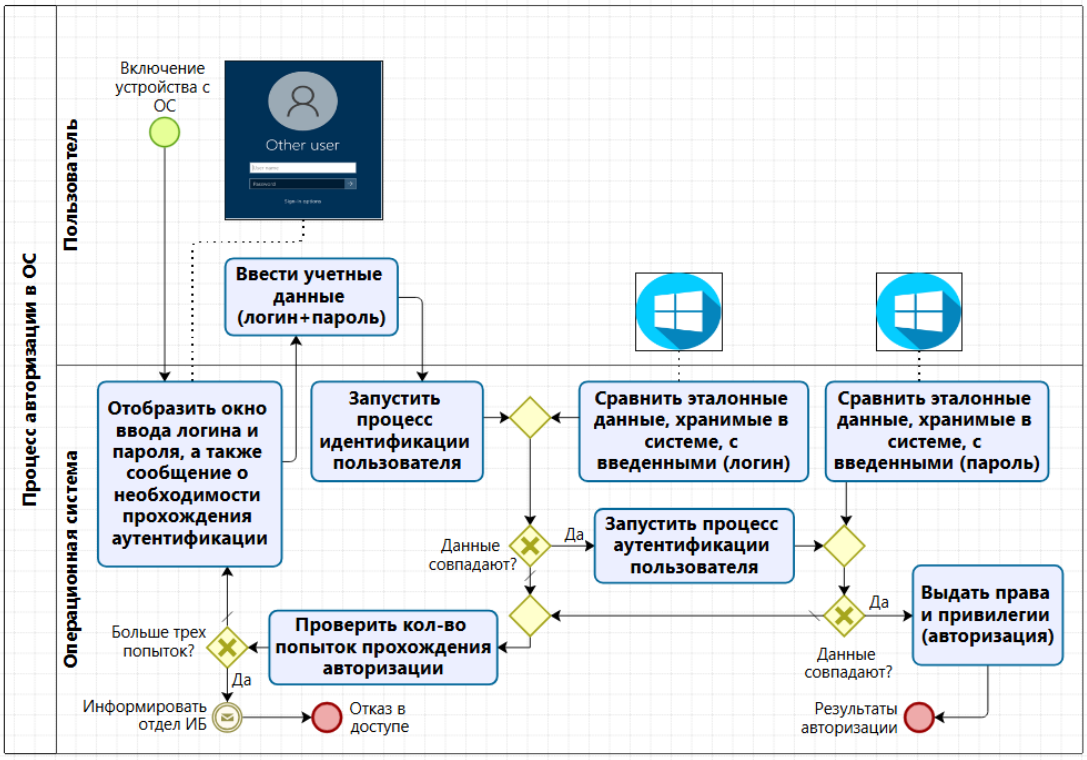



Рисунок 6 – Подпроцесс “Пройти авторизацию в ОС”

В случае успешного прохождения авторизации менеджер по подбору кандидатов инициирует взаимодействие с утвержденным кандидатом, отправляя на его личный адрес электронной почты запрос на предоставление сканов персональных данных (ПДн). Кандидат, в свою очередь, отправляет

конфиденциальные документы по тому же незащищенному каналу. Этот обмен представляет собой критическую уязвимость, так как передача чувствительных данных через публичные почтовые сервисы напрямую нарушает требования ФЗ-152 «О персональных данных» и создает высокий риск их перехвата и компрометации.

Полученные сканы документов сохраняются менеджером в локальной папке на рабочем компьютере, а сами данные вносятся в незащищенную таблицу Excel. На основе этих данных готовятся трудовые документы, при этом ручной ввод повышает вероятность ошибок, а неконтролируемое хранение файлов на локальной машине - риск их утечки.

Для подготовки рабочего места и создания учетной записи специалист по делопроизводству отправляет отдельные письма в смежные отделы. Наиболее критичным моментом на этом этапе является получение от ИТ-отдела ответного письма, содержащего логин и пароль нового сотрудника в открытом, незашифрованном виде. Это является нарушением политик безопасности и может привести к компрометации учетной записи еще до того, как сотрудник начнет свою работу.

Завершающие этапы процесса также сопряжены с рисками. Передача бумажных документов на подпись руководителю несет угрозу физической утери или несанкционированного ознакомления. Архивирование документов в двух видах - бумажном (в офисном шкафу) и электронном (на локальном ПК) - приводит к риску рассинхронизации версий, усложняет контроль и повышает вероятность утечки данных при несанкционированном доступе как к физическому, так и к электронному архиву.

Анализ построенной BPMN-модели “как есть” показывает, что текущий процесс трудоустройства кандидата характеризуется критическим уровнем рисков информационной безопасности. Ключевыми уязвимостями являются использование незащищенных каналов связи для передачи персональных и аутентификационных данных, неконтролируемое хранение чувствительной информации на локальных АРМ, отсутствие формализованных процедур и

средств аудита. Данный процесс не соответствует требованиям законодательства РФ в области защиты персональных данных. Построенная модель является основанием для дальнейшего проектирования модели “как будет” с внедрением автоматизированной системы в защищенном исполнении, которая позволит устранить или минимизировать выявленные угрозы.

**Выводы по проделанной работе**

В результате выполнения заданий лабораторной работы были решены следующие задачи:

- Была построена модель “как есть” для торговой компании «Гамма» с точки зрения сотрудника ИБ;
- Была построена и описана модель “как есть” для процесса учета кадров маркетинговой компании ООО “Маркетинг с умом”, а именно этап трудоустройства утвержденного кандидата;
- Выполнен анализ результатов построения статистической модели “как есть” для этапа трудоустройства утвержденного кандидата, в ходе которого были выявлены множественные нарушения информационной безопасности.